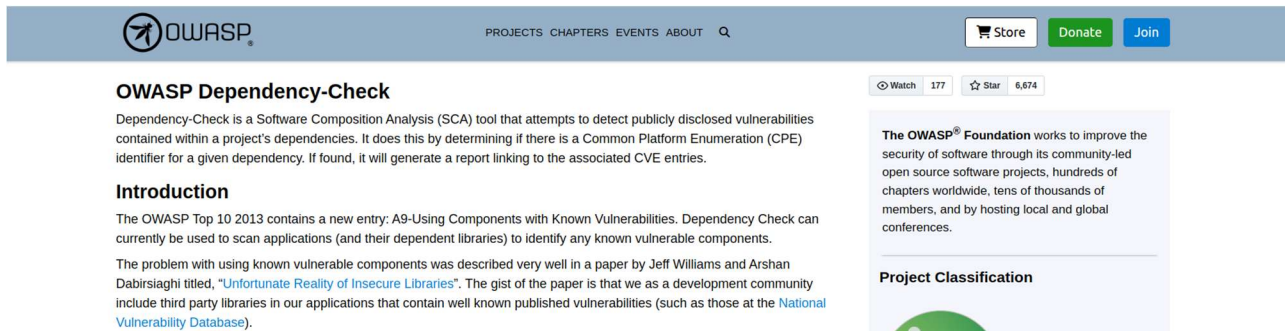


Integrating OWASP Dependency Check

1. Overview



The screenshot shows the GitHub repository page for OWASP Dependency-Check. The header includes the OWASP logo, navigation links (PROJECTS, CHAPTERS, EVENTS, ABOUT), and buttons for Store, Donate, and Join. The main content area features the repository name, a description of the tool as a Software Composition Analysis (SCA) tool, and an introduction section. The introduction mentions the OWASP Top 10 2013 entry A9-Using Components with Known Vulnerabilities and references a paper by Jeff Williams and Arshan Dabirsiaghi titled "Unfortunate Reality of Insecure Libraries". A sidebar on the right contains a 'Project Classification' section with a green circular icon.

OWASP Top 10 Proactive Controls describe the most important security controls that should be adopted in every secure software development project. One of the proactive controls is C2: Leverage Security Frameworks and Libraries, and one of the best practices for this control is to proactively keep them up to date possibly with the help of tools, e.g., OWASP Dependency Check – a Software Component Analysis (SCA) tool to detect publicly disclosed vulnerabilities contained within the dependencies of a project.

In this Lab 6, you are going to learn how to integrate OWASP Dependency Check into your local development, so that you are able to incorporate dependency check into your team project.

2. Outcomes

Upon completion of this session, you should be able to:

- Use OWASP Dependency Check for local web app development
- Incorporate OWASP Dependency Check into Github Actions

3. Tutorial

1. Reference

When trying OWASP dependency check for your team project, you are likely unable to find a reference on the Internet that can fully meet your needs. Nevertheless, it is hoped that through the team project, you are able to acquire the skill of adapting what was available, couple with your knowledge and understanding, and eventually find the solutions.

2. Pre-requisite

Docker Desktop in your development laptop

Docker Engine in Team VM

Github Account

Team project web app

3. OWASP Dependency Check Using Docker

Pull the Dependency Check Image

```
docker pull owasp/dependency-check
```

Run the Scan, this command is for linux or mac os, please replace with your project src path. And adapt the command for running in windows, if necessary.

(Replace with your project src path)

```
export pwd=/home/cloak/site/
```

```
docker run --rm \
  -v $pwd:/src \
  -v $pwd/odc-reports:/report \
  -v $pwd/odc-data:/usr/share/dependency-check/data \
  owasp/dependency-check \
  --scan /src \
  --format "HTML" \
  --out /report
```

The HTML Report is created in odc-reports/.

4. OWASP Dependency Check in GitHub Actions

Create a .github/workflows/dependency-check.yml file

```
name: OWASP Dependency Check

on: [push, pull_request]

jobs:
  security-scan:
    runs-on: ubuntu-latest
    steps:
      - name: Checkout Code
        uses: actions/checkout@v4

      - name: Run OWASP Dependency Check
        uses: dependency-check/Dependency-Check_Action@main
        with:
          project: "MyWebApp"
```

```
    path: "."
    format: "HTML"
    out: "dependency-check-report"

- name: Upload Report
  uses: actions/upload-artifact@v4
  with:
    name: Dependency-Check-Report
    path: dependency-check-report
```

This workflow:

- Runs on `push` and `pull_request`
- Scans the repository
- Generates a report
- Uploads the report as an artifact in GitHub Actions

Commit the `dependency-check.yml` file and you can view the status and report on your Github page.

5. Other Dependencies Check Tools

There are other dependencies check tools that you can explore and use for your project. For example, Dependabot or Renovate.

Dependabot

Checks for outdated dependencies and automatically creates pull requests to update them. Dependabot works with package managers like npm, Maven, Gradle, Composer,

pip, etc. It only checks against known dependency registries (e.g., npm, PyPI, Maven Central).

Example Dependabot configuration (`.github/dependabot.yml`):

```
version: 2
updates:
  - package-ecosystem: "npm" # or "maven", "gradle", "pip"
    directory: "/"
    schedule:
      interval: "daily"
```

Congratulations! You have successfully completed the use of OWASP Dependency Check for your lab. We hope that you are now ready to try incorporating dependency check into your team project. Enjoy!

END OF DOCUMENT